

第五輪小白卡關修補法律與合規警告 (v3.41)



本檔性質：客戶毛利率、訂單跟單、寄 PDF email、FAQ、資料健康檢查、Chat 回饋之合規提醒，不構成法律意見。累積適用於 v3.25.10 → v3.40 全部 \$6 聲明。

English version: [POLISH_V341_LEGAL_NOTICE_EN.md](#)

⚠️ 客戶務必由 CPA / 法律顧問 / 內控主管 + 行銷 / 業務主管覆核後正式上線。

⚠️ v3.41 涉及之高度敏感對外功能

功能	風險等級	對外 / 對內
寄 PDF Email 給客戶 (P5)	● 對外溝通	對外，有契約風險
客戶毛利率分析 (P1)	● 議價策略敏感	對內，不可外流
訂單跟單 (P2)	● 業務透明度	對內
資料健康檢查 (P8)	● IT 內控	對內
Chat thumbs feedback (P7)	● 員工回饋	對內
FAQ (P6)	● 靜態問答	對內

1. 寄 PDF Email 給客戶 (P5) 🏛️ 法律最敏感

1.1 行為

- LLM 講「寄 QUO-001 給 ABC」→ 出 ConfirmCard
- 確認後產生 PDF + 透過 SMTP 寄附件給客戶 contact_email
- 預設 TTL 15 分鐘 (比一般 30 分鐘更短 — 強調慎重)

1.2 法律風險 (極重要)

對外 Email 之 PDF 可能構成法律意義之「要約」「承諾」「告知」：

- ● 報價單：可能構成「要約之邀請」(invitation to treat)；若客戶誤解為「要約」並承諾 → 契約成立之爭議

- ● 銷售訂單：可能構成「承諾」(acceptance)；客戶可主張價格 / 規格 / 交期已確定
- ● 出貨單：物權移轉之依據；錯誤寄送 = 帳目失控
- ● 發票相關文件：須符合統一發票使用辦法，erpilot 之 PDF 不是統一發票

1.3 寄錯收件人之風險

- ● 客戶資料外洩 (個資法第 27 條)
- ● 商業機密外洩 (營業秘密法)
- ● 競爭對手取得議價情報
- ● 客戶對客戶之誤導 (A 客戶看到 B 客戶之價格)

1.4 客戶內控義務 (強制)

導入此功能前必須：

- ☐ 指派對外 Email 之「最終覆核人」(通常為業務主管 / 老闆)
- ☐ 限制 `sales.order.update` 權限給經授權人員
- ☐ 建立「寄送前清單覆核」SOP (收件人 / 主旨 / 附件正確)
- ☐ 設定SMTP 之寄件回條追蹤
- ☐ 訂定寄錯後之「召回 / 道歉」流程
- ☐ 教育員工：寄送即不可收回 (除非有對方 IT 配合)

1.5 SMTP 配置之安全要求

- ✗ 不要使用個人 Gmail / Yahoo (容易被誤判垃圾郵件)
- ✓ 應使用公司網域之 SMTP (如 `noreply@yourcompany.com.tw`)
- ✓ 配置 SPF / DKIM / DMARC 提升送達率 + 防偽
- ✓ 開啟寄送 audit log (誰 / 何時 / 寄給誰 / 寄什麼)

1.6 erpilot 之責任邊界

於適用法律所允許之最大範圍內：

- erpilot 提供寄送工具，不驗證 PDF 內容之正確性
- erpilot 不驗證收件人之真實性
- erpilot 不自動處理「召回 email」
- erpilot 不承擔因寄錯收件人 / 寄錯內容所致之任何契約爭議、個資外洩、商業損失

1.7 SMTP 未設定時之 dry-run

- 若 `SMTP_HOST` / `SMTP_FROM` 未設定 → 自動 dry-run (不真寄)
- dry-run 模式僅顯示預覽，不會洩漏資料
- 但客戶不應以為 dry-run = 無風險 — 真實寄送前須先測試

2. 客戶毛利率分析 (P1) ⚖️ 議價策略敏感

2.1 行為

- LLM 講「哪 5 個客戶最賺」「ABC 賺不賺錢」
- 系統計算 $(\text{revenue} - \text{cost}) \div \text{revenue} \times 100\%$
- 列出 top N 並標 ●●● 等級

2.2 法律 / 商業敏感

毛利率資料屬於：

- 公司內部議價策略 (核心商業機密)
- 若外流給員工：可能用於跳槽攜帶資訊 (違反保密義務)
- 若外流給客戶 A：客戶 A 可主張「同業 B 賺比較少 → 我也要降價」
- 若外流給競爭對手：等同送情報

2.3 客戶內控義務

- 限制 `sales.order.read` 權限僅給經授權之主管
- 不得截圖 / 列印 / 匯出毛利率分析
- 員工簽署保密協議含「毛利率屬於營業秘密」之明確條款
- 對員工內訓時強調「即使在私下對話也不可洩漏」

2.4 計算方法之限制

- 成本以 `Product.standard_cost` 為準 — 不含人工、製造費用、行銷費
- 不含退貨 / 折讓之沖銷
- 不含呆帳損失
- 不含機會成本 (產能被低毛利客戶佔用之損失)
- 客戶正式財報分析應由會計師用更完整的方法

2.5 erpilot 免責

erpilot 提供之毛利率為啟發式分析，不取代正式財務分析；erpilot 對因依賴此分析所做之議價決策、客戶取捨所致之損失，不承擔責任。

3. 訂單跟單 (P2)

3.1 行為

- 講「QUO-001 後續變成什麼」→ 顯示 Quote → SO → 出貨 → 應收 → 收款 timeline

3.2 風險

- timeline 含契約執行細節
- 若給競爭對手：洩漏交易結構
- 若給客戶 (看自己的訂單可能 OK，但其他客戶不行)：個資 / 商業機密

3.3 客戶責任

- 限制權限：`sales.order.read`
- 對外提及具體交易須取得對方同意

4. 資料健康檢查 (P8)

4.1 行為

- 檢查重複客戶 / 重複料件 / BOM 循環 / 孤兒庫存 / 無 email 客戶 / 無成本料件
- 顯示 ●●●● 嚴重度

4.2 限制

- 健康檢查為啟發式偵測
- 結果不取代正式 IT 稽核 / 內控查核
- 客戶之特殊業務規則不在此工具偵測範圍

4.3 客戶責任

- 健康檢查發現之問題由 IT / 內控主管處理
- 不應讓非 IT 員工直接處理 (可能造成更大資料污染)

5. Chat Thumbs Feedback (P7)

5.1 行為

- 使用者按 👍 / 👎 → 寫到 AuditLog (action="chat.feedback")

5.2 員工監督邊界

- Feedback 含員工對系統的滿意度 → 可能用於員工績效評估
- 客戶應告知員工：此 feedback 為改善系統用，不用於人事考核
- 若用於人事考核，須事前告知並取得同意

5.3 個資處理

- Feedback 之 **comment** 欄位可能含自由文字 (員工可能寫敏感資訊)
- 客戶須定期審視並遮罩敏感欄位
- 保存期應與員工資料一致

6. FAQ (P6)

6.1 行為

- 靜態 8 個常見問題 (價格 / 斷網 / 多人 / 備份 / API key / 升級 / 改密碼 / ConfirmCard)

6.2 限制

- FAQ 為啟發式提示，不取代正式合約 / SLA / 技術支援
- 「價格」部分為公開估價，實際價格以正式報價單為準

7. 案例：常見錯誤使用模式

7.1 ❌ 不該做

- 寄 PDF 給錯誤客戶 (如 A 客戶之報價單寄到 B 客戶)
- 把毛利率分析截圖傳到 LINE 群組
- 用毛利率資料作為員工 KPI 之依據 (員工會找客戶吵架)
- 跟客戶口頭提及其他客戶之 timeline
- 在沒設定 SPF/DKIM 之狀況下大量寄客戶 email (容易被當垃圾郵件)

7.2 ✅ 應該做

- 寄 email 前人工覆核收件人 + 附件
- 毛利率分析僅在主管會議討論，不留紙本
- 用毛利率分析作為內部議價策略，不外流
- 訂單跟單僅內部追蹤用
- SMTP 使用公司網域 + SPF/DKIM/DMARC 配置

8. 免責條款 (累積適用 v3.25.10 → v3.41)

於適用法律所允許之最大範圍內：

1. 寄 PDF Email erpilot 不驗證 PDF 內容、收件人真實性、寄送結果之契約效力。erpilot 對因寄送所致之任何契約爭議、個資外洩、商業損失、客戶混淆、競爭對手洩密，**不承擔責任**。
2. 客戶毛利率分析 erpilot 提供之毛利率為啟發式分析 (standard_cost-based)，不取代正式財務 / 會計師分析。erpilot 對因依賴此分析之議價決策、客戶取捨、商業策略所致之任何損失，**不承擔責任**。
3. 訂單跟單 erpilot 不保證 timeline 之完整性；對因 timeline 外流所致之個資、商業機密爭議，**不承擔責任**。
4. 資料健康檢查 erpilot 之檢查為啟發式偵測，不取代正式 IT 稽核。erpilot 對未被偵測之資料品質問題所致之損失，**不承擔責任**。
5. Chat Feedback erpilot 不監督客戶對 feedback 之使用方式；若客戶用於員工人事考核所致之勞資爭議，erpilot **不承擔責任**。
6. FAQ 答案為功能性參考，不取代正式契約 / SLA / 技術支援。價格部分以正式報價單為準。

9. 客戶導入前 Checklist (v3.41 強化)

9.1 對外溝通 (Email) ⚠️ 最重要

- ☐ 已指派對外 Email 之最終覆核人
- ☐ 已限制 `sales.order.update` 權限給經授權之 2-3 人
- ☐ 已配置公司網域 SMTP + SPF / DKIM / DMARC
- ☐ 已訂定寄錯之召回 / 道歉 SOP
- ☐ 已測試真實 SMTP 寄送 + 寄件回條

9.2 議價策略 (毛利率)

- ☐ 已限制毛利率分析權限給經授權主管
- ☐ 員工簽署保密協議含毛利率條款
- ☐ 已訂定「毛利率討論僅限主管會議」之政策

9.3 員工 Feedback

- ☐ 已告知員工：Chat thumbs 為改善系統用，不作 KPI
- ☐ 已訂定敏感 feedback 之遮罩流程

9.4 資料健康

- ☐ 已指派IT 主管負責週期性檢查
- ☐ 已訂定異常處理流程 (不讓非 IT 員工直接改)

9.5 與既有 checklist 累積

- ☐ 已完成 v3.25.10 → v3.40 之全部 checklist

10. 國際法 / 跨國使用警告

地區	額外法律	對 v3.41 影響
eu EU	GDPR Art. 6 / 32	Email 寄送須合法基礎；客戶資料最小化
us US (CAN-SPAM)	CAN-SPAM Act	Email 必須含 opt-out 連結 + 公司地址
us US (CA)	CCPA	客戶有「不被販售」權利 — 毛利率分析不可用於對外議價
cn China	PIPL	Email 跨境寄送須單獨同意
jp Japan	APPI	客戶資料用途變更需通知
sg SG	PDPA	DNC 名單對行銷 email 有限制

⚠️ erpilot 之 SMTP 寄送不自動加上 unsubscribe link / 公司地址 — 客戶須自行符合上述規定。

版本：v3.41 (2026-05-22) 作者：erpilot 法務團隊 (內部) 對應程式：

- `backend/app/agents/domains/polish_v341_tools.py` (5 LLM tools + email helper)
- `backend/app/api/chat_feedback.py` (P7 feedback endpoint)
- `frontend-desktop/src/pages/Chat.tsx` (briefMode / pin / thumbs UI)